

Example project - Facial-recognition access control

Non-canonical model-validation example.

The example intentionally includes ML and biometric concepts because they belong to the application domain. The Macro Requirements remain independent from lower-level architecture choices such as inference placement, device interconnection and command protocols; those choices belong to later Decisions.

For comparability with the current ThreatForge project-model convention, this example uses textual identifiers **MR-0001** through **MR-0004**. The general metamodel still treats the concrete ID encoding as a deferred Doc-as-Code representation decision.

Project summary

The project controls access to a reserved physical area. A camera observes a person at the access point, facial recognition is used to determine whether the person corresponds to an authorized identity, and access is granted by opening a turnstile when the project's access conditions are satisfied.

The MR set describes stable project concerns rather than the progress of architectural design. Placement of ML inference, network topology, device protocols and similar solution choices are therefore omitted from the MR bodies and can be governed later through Decisions and Requirements.

MR-0001 - Accesso controllato all'area riservata

Intent

Consentire alle persone autorizzate di accedere a un'area riservata in modo rapido e controllato, evitando che il varco si apra automaticamente quando l'autorizzazione non è stata confermata.

Context

L'area è protetta da un tornello. Il progetto usa il riconoscimento del volto come parte della decisione che precede l'apertura automatica del varco.

Stakeholders

- persone autorizzate;
- responsabili dell'area riservata;
- addetti alla sicurezza fisica;
- personale operativo che gestisce il punto di accesso.

Objective

- Rendere l'accesso automatico coerente con lo stato di autorizzazione della persona.
- Mantenere controllabile il comportamento del varco anche quando il riconoscimento non produce un risultato utilizzabile.

Scope - candidate under test

- il passaggio dal tentativo di ingresso alla decisione di aprire o non aprire il varco;
- l'esperienza macro della persona al punto di accesso.

DependsOn

- MR-0002 Gestione delle persone autorizzate.
- MR-0003 Riconoscimento facciale per la verifica della persona.

MR-0002 - Gestione delle persone autorizzate

Intent

Consentire all'organizzazione di stabilire chi può accedere all'area riservata e di mantenere aggiornata nel tempo l'associazione tra persona, autorizzazione e informazioni necessarie al riconoscimento.

Context

Le autorizzazioni cambiano nel tempo: una persona può essere abilitata, sospesa o non più autorizzata. Il sistema di riconoscimento deve usare informazioni coerenti con lo stato corrente deciso dall'organizzazione.

Stakeholders

- responsabili dell'area;
- amministratori delle autorizzazioni;
- persone autorizzate;
- personale incaricato dell'onboarding e della revoca.

Objective

- Mantenere una fonte governata delle persone autorizzate e del loro stato di accesso.
- Mantenere coerenti le informazioni necessarie al riconoscimento con il ciclo di vita dell'autorizzazione.

Scope - candidate under test

- inserimento, aggiornamento, sospensione e revoca delle autorizzazioni;
- associazione tra identità autorizzata e informazioni utilizzate per riconoscerla.

MR-0003 - Riconoscimento facciale per la verifica della persona

Intent

Determinare se il volto osservato al punto di accesso corrisponde a una persona autorizzata con qualità sufficiente per supportare la decisione di accesso.

Context

Il progetto utilizza una telecamera e un modello di machine learning per il riconoscimento facciale. Il modello può richiedere immagini o sequenze video adeguate e può produrre risultati incerti o errati.

Stakeholders

- persone che si presentano al varco;
- addetti alla sicurezza;
- responsabili del servizio di accesso;
- specialisti che mantengono il sistema di riconoscimento.

Objective

- Ottenere dal volto osservato un risultato di riconoscimento utilizzabile dal processo di accesso.
- Rendere distinguibili i casi di riconoscimento positivo, mancato riconoscimento e risultato non sufficientemente affidabile.
- Consentire che la qualità del riconoscimento possa essere valutata e migliorata nel tempo.

Scope - candidate under test

- acquisizione delle informazioni visive necessarie al riconoscimento;
- esecuzione e valutazione del riconoscimento facciale;
- risultato fornito al processo che decide l'accesso.

Assumptions

- il riconoscimento facciale e una capacita prevista dal progetto, non una tecnica scelta solo per una metodologia di analisi.

MR-0004 - Uso responsabile dei dati biometrici e delle decisioni automatiche

Intent

Proteggere le persone coinvolte nell'uso del riconoscimento facciale assicurando che dati biometrici e decisioni automatiche siano trattati in modo comprensibile, controllabile e coerente con le finalita di accesso del progetto.

Context

Il riconoscimento facciale utilizza informazioni biometriche e puo produrre errori che incidono sull'accesso fisico di una persona. Questi aspetti fanno parte del dominio e del valore del progetto indipendentemente dalla metodologia di analisi che potra essere applicata.

Stakeholders

- persone i cui dati biometrici sono trattati;
- responsabili dell'organizzazione;
- responsabili privacy/compliance applicabili al contesto;
- addetti che gestiscono contestazioni o eccezioni di accesso.

Objective

- Limitare l'uso dei dati biometrici alle finalita governate dal progetto.
- Rendere governabili il ciclo di vita dei dati biometrici e gli effetti degli errori di riconoscimento.
- Consentire responsabilita e revisione delle decisioni automatiche che incidono sull'accesso.

Scope - candidate under test

- trattamento dei dati biometrici utilizzati dal progetto;
- conseguenze e revisione delle decisioni automatiche di riconoscimento nel contesto dell'accesso.

Why there is no separate MR for PC/LAN/edge architecture

PC, LAN, inference on the camera, inference on an edge computer and the protocol used to command the turnstile are solution choices rather than independent project macro-concerns in this example. They are candidate **Decisions** below the relevant MR branches.

A different MR structure would be justified only if a property that currently looks architectural became an independently valued project outcome with its own stakeholder meaning. For example, a project-wide requirement for autonomous operation without external connectivity could reveal a distinct macro concern. This is a test for the MR boundary, not temporary status text to place inside an MR.

Candidate split test: ML model lifecycle

In this example, model training, deployment, threshold selection and model update are treated as lower-level concerns of MR-0003 because they serve the single macro intent of facial recognition at the access point.

A separate MR for **ML model lifecycle** would be justified only if the project treats model production/governance as an independent macro capability with its own stakeholders, objectives and Decisions (for example, if the product itself includes a reusable organizational ML model-management service).

Observation for the future analysis metamodel

This example exposes an important distinction that should be preserved for the later analysis-model study rather than encoded into the MR structure itself.

Different parts or concerns of one governed project may benefit from different analysis paradigms:

- MR-0003 is a natural candidate for later analysis with an AI/ML-oriented threat-analysis method such as STRIDE-AI, because the project concern includes an ML-based recognition capability and model-specific failure or abuse questions may become relevant;
- MR-0004 is a natural candidate for a privacy-oriented analysis because it concerns biometric data and effects on people. Privacy-specific analysis is outside the thesis implementation scope, but the example demonstrates why a general governance model should not assume that one analysis methodology covers every relevant concern equally well.

The working lesson is **not** that an MR owns one methodology. The lesson is that later analysis should be able to select a method for an explicit analysis scope or set of governed subjects. Different methods may therefore analyze different, overlapping or complementary parts of the same project.

Their outputs must still converge into one governed project/documentation lifecycle: findings, documentation gaps, proposed requirements and other feedback should remain traceable to the same governed project knowledge and return through common review and documentation-evolution mechanisms.

This observation is intentionally deferred to the future analysis metamodel. It must not be used to add STRIDE-AI, privacy or other method-specific fields to Macro Requirements.

What this example tests

1. Domain-specific technical terms can appear in MR when they are natural to the project stakeholders.
2. Lower-level architecture choices are omitted from MR bodies rather than described through temporary statements such as “not yet decided”.
3. ML can be represented at MR level without introducing a threat-analysis or privacy-analysis methodology.
4. Cross-MR dependencies can express collaboration without creating a false hierarchy between independent macro concerns.
5. A single project can expose concerns suited to different later analysis paradigms without partitioning the MR model by methodology.
6. Results from different analyses should ultimately return to one governed project/documentation lifecycle; the detailed mechanism remains a future analysis-metamodel question.
7. Intent/Objective and Scope remain under evaluation: this example should be used to detect duplication before those concepts are frozen.